

CSE 331: Computer Security Fundamentals

Spring 2026

Firewalls and Tunnels

Amir Rahmati
Xinrui Yu



Stony Brook Institute
at Anhui University

安徽大学纽约石溪学院

Prof. Rahmati Schedule

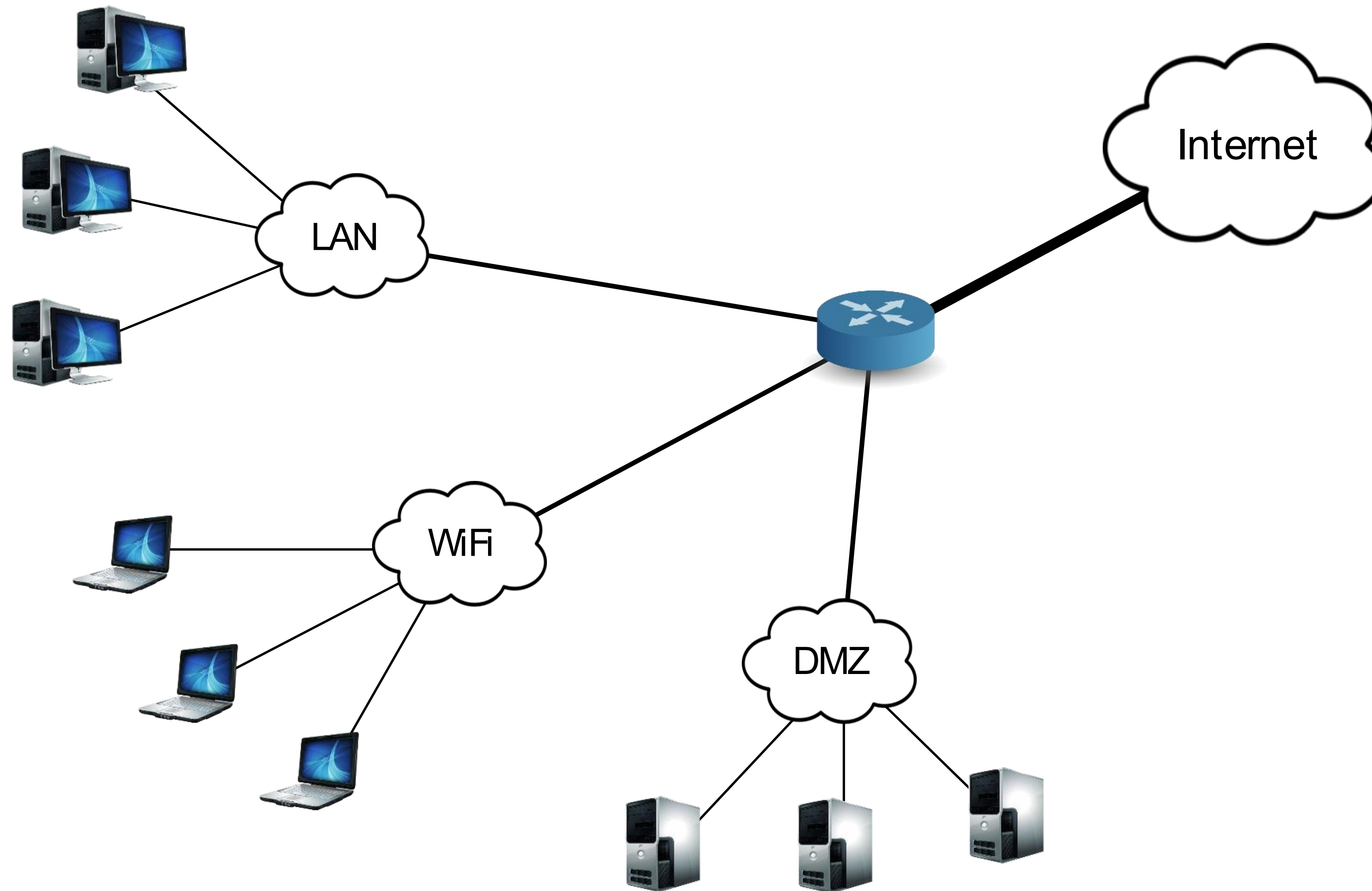
[illegible]

Midterm

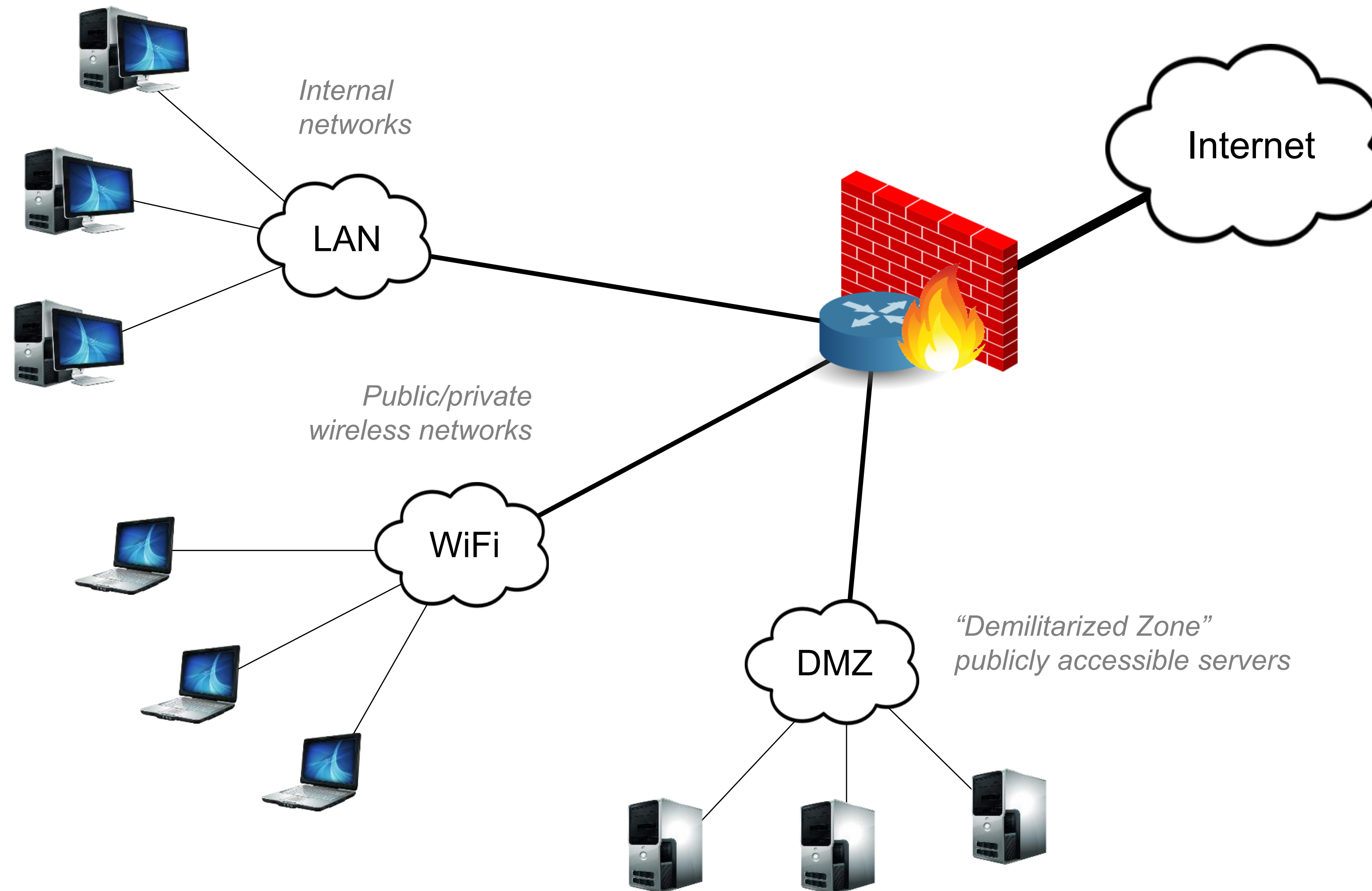
April 26, 10:20 – 12:20

- Topics: Basic Crypto to Firewalls
 - Closed-book, closed-notes
 - Answer in English
 - Bring 2B pencils
-
- You should review practice questions and quizzes

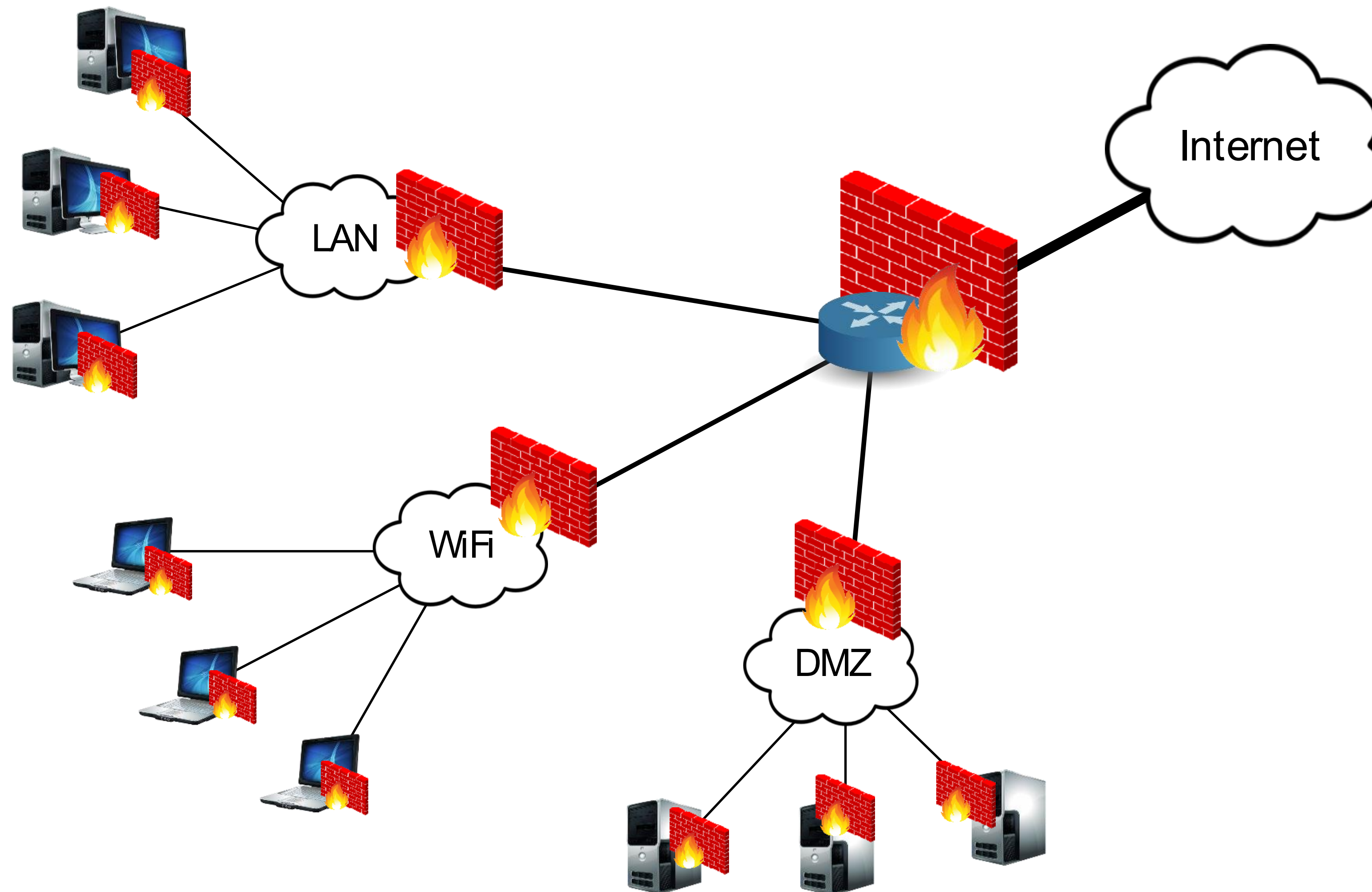
Typical Network Topology



Firewalls: separate local networks from the Internet



Firewalls: Reality



Firewalls

- **Filter traffic according to a predefined policy**

Mostly statically defined, but dynamic updates are possible (block an ongoing DoS attack, protocols with dynamically negotiated port numbers, etc.)

- **Main strategies**

Default-deny: drop everything unless explicitly allowed

Default-allow: block specific protocols/hosts/ports/

Firewalls: why are they needed?

- **Hosts may run vulnerable services: prevent outside access**

Limit the “attack surface”, expose fewer services

- **Internal hosts may get compromised: damage control**

Prevent propagation, outgoing attacks, exfiltration, ...

- **Hide the structure of private networks: hinder network reconnaissance**

Block port scanning, service fingerprinting, ...

- **Network intelligence: log interesting events**

Troubleshooting, monitoring/tuning, auditing, forensics, ...

- **Simply block unwanted traffic: policy enforcement**

Noise, backscatter, spoofed packets, DoS attacks, brute-force password guessing, file sharing, social networking, streaming services, games, VPNs, ...

A Theory of Firewalls (Bellovin)

Three properties must hold for a firewall to be effective

1. The firewall should be placed at a topological chokepoint

Not always true in modern enterprises: links to suppliers/contractors, cellular connectivity, VPN/proxy software, ...

2. “Inside” nodes share the same security policy

Do they? BYOD (Bring Your Own Device), IoT, work from home, ...

3. “Inside” nodes are trusted, “outside” hosts are untrusted

- BYOD: an already infected device may appear inside the network
- Internal hosts can be infected due to client-side attacks (e.g., drive-by download attacks, malware, phishing, supply chain attacks, ...)
- Insider threats, disgruntled employees, ...

Stateless and Stateful Firewalls

Stateless Firewalls

- **Policy decisions by considering each packet in isolation**

Rules mostly based on network and transport layer fields

Simple implementation: no need to keep state

- **Limitations**

Dynamically negotiated/non-standard port numbers (FTP, SIP, BitTorrent, ...)

Connectionless protocols (e.g., UDP): cannot distinguish between queries and replies

IP fragmentation: port numbers are present only in the first fragment

Rule sets can get complex and hard to understand

Still useful for simple scenarios

Ingress/egress filtering, strict configurations, ...

Stateless Firewalls and TCP

- **Common configuration (e.g., typical home network): block incoming but allow outgoing connections**

Incoming (externally initiated) connections should be blocked

Incoming packets of established connections should be allowed

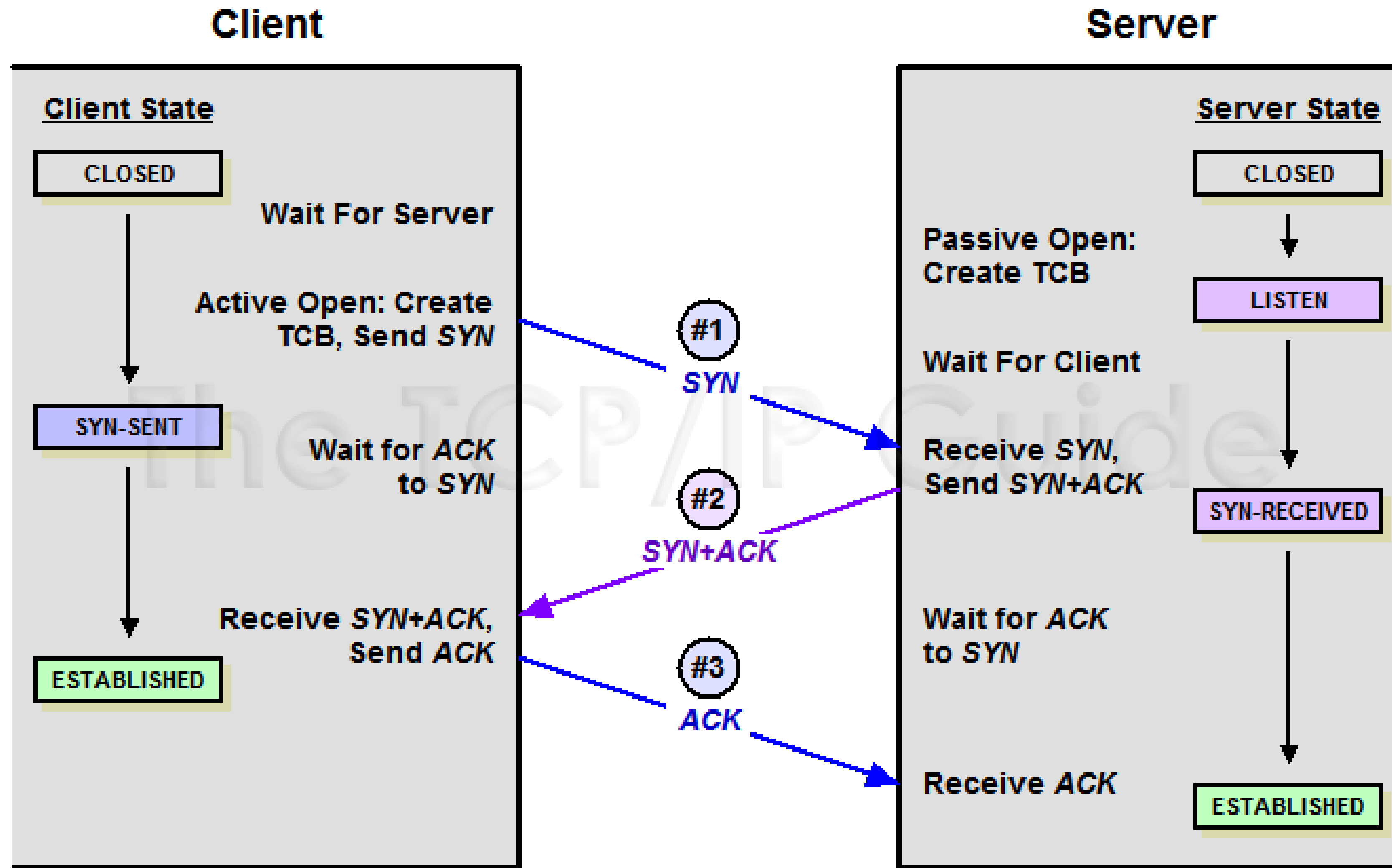
- **Can be achieved without keeping state**

Block incoming SYN-only packets

Allow incoming packets with the ACK bit set

- **Not an ideal solution: ACK scanning**

Recap: TCP 3-Way Handshake



ACK Scanning (nmap -sA)

Can determine whether a stateless firewall is used

Not whether a specific port is open or not

When an ACK is sent to a closed port, or sent out-of-sync to an open port, the expected behavior is to respond with a RST

Stateful firewalls discard out-of-sync ACK packets, leading to no response

Step 1: SYN -> SYN/ACK or RST

Step 2: ACK -> RST *The port is unfiltered by any firewall type*

Step 1: SYN -> SYN/ACK

Step 2: ACK -> no response *Stateful firewall*

Step 1: SYN -> no response

Step 2: ACK -> RST *Stateless firewall*

Stateful Firewalls

- **Firewall keeps per-connection state**

Track TCP three-way handshake, UDP query/responses, ...

Decisions are made by considering each packet in the context of the connection/session it belongs to

- **Most common firewall type, more flexible policies**

Internally vs. externally initiated connections/sessions

- **Still cannot handle dynamically negotiated port numbers and higher-level protocol semantics**

Missing application-level context

Network Address Translation

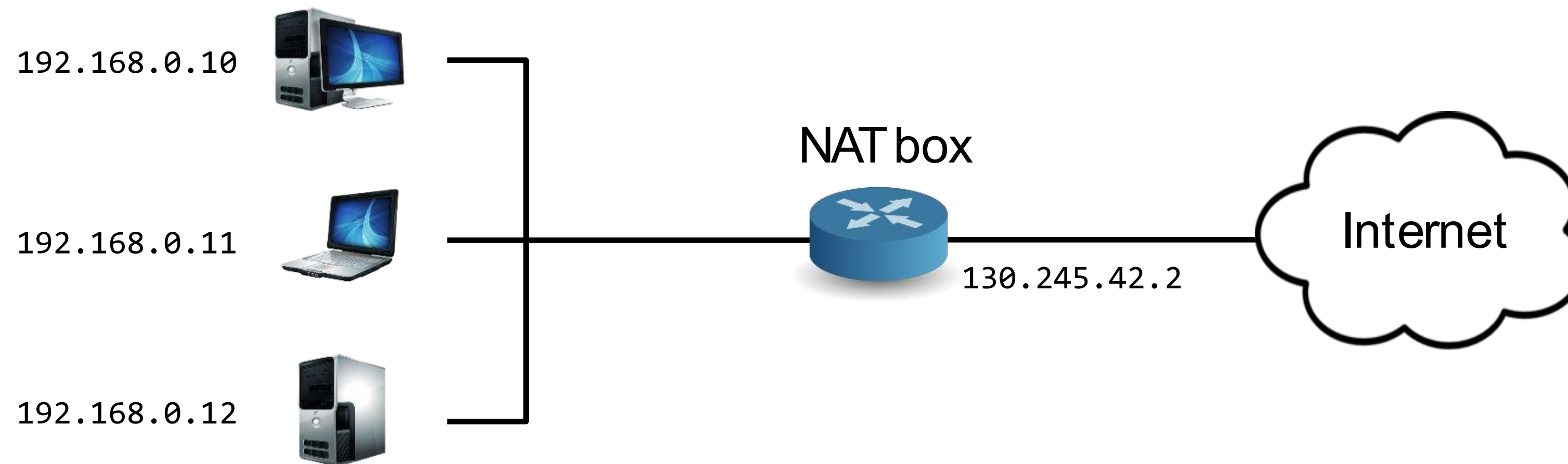
Share a public IP address with many internal hosts

In general: remap an IP address space into another address space

Global shortage of IPv4 addresses

Widely used (home networks, wireless networks, ...)

Rewrite packet address and port information (per-connection state)



NAT vs. Stateful Firewall

Similar functionality and state

NAT in addition **modifies** packets: performs address/port translation

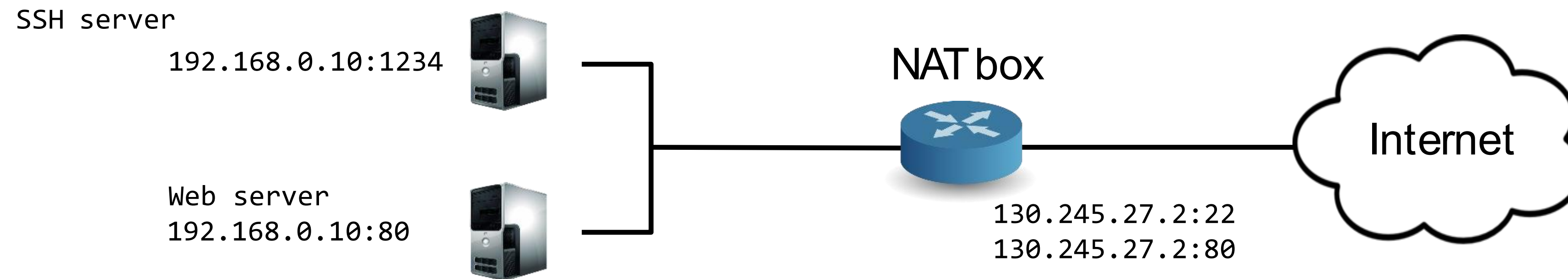
Are NATs firewalls?

Not in the strict sense, as they do not fully track the TCP 3-way handshake or any other higher-layer state

But they inherently *do* enforce a default firewall policy: block incoming and allow only outgoing connections

Internal hosts can become accessible through *port forwarding*

Explicitly map a local IP:port to a public IP:port



Host-based Firewalls

- **Firewalls running on end hosts**

Windows firewall

IPtables

- **“Personal” firewalls: apply common-sense policies (deny incoming, allow outgoing)**

Particularly important for home users, laptops, etc.

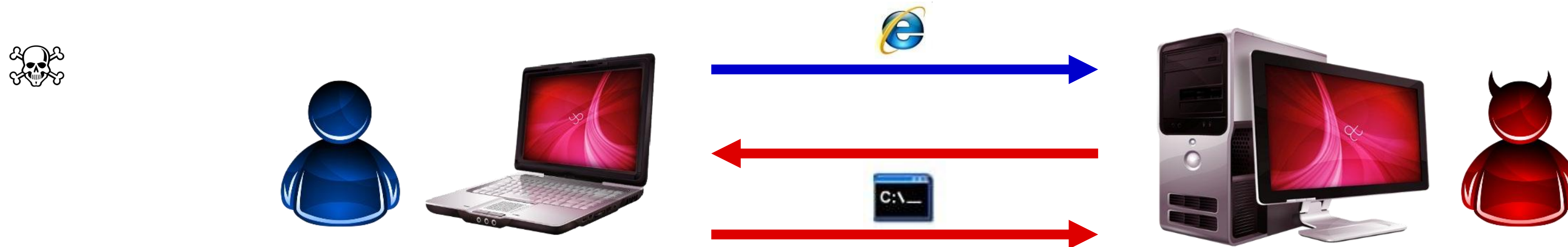
- **On-by-default client firewall deployment contributed significantly in ending the era of internet worms**

Starting with Windows XP SP2

Before host-based firewalls: attacker connects to victim



After host-based firewalls: victim connects to attacker



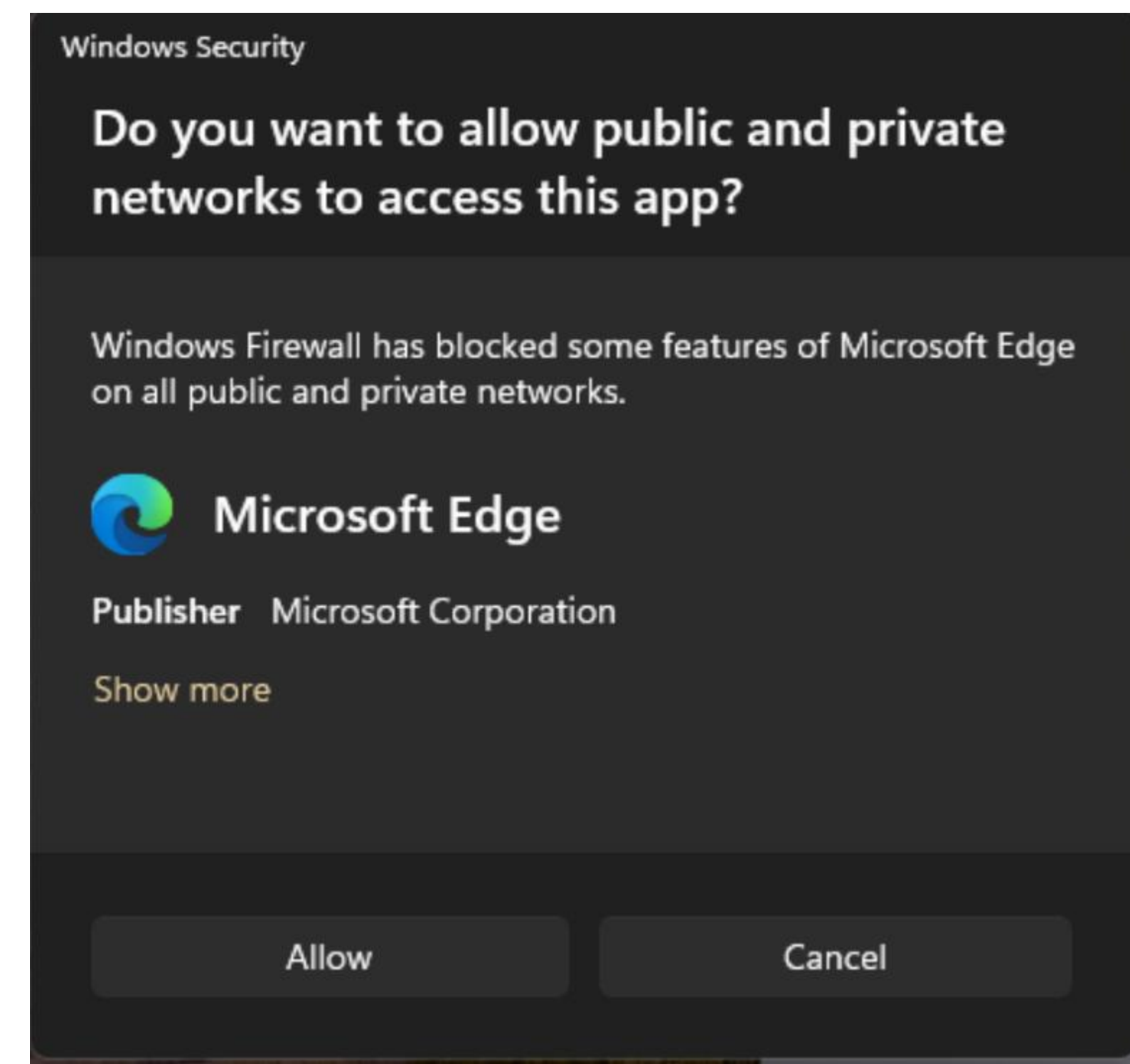
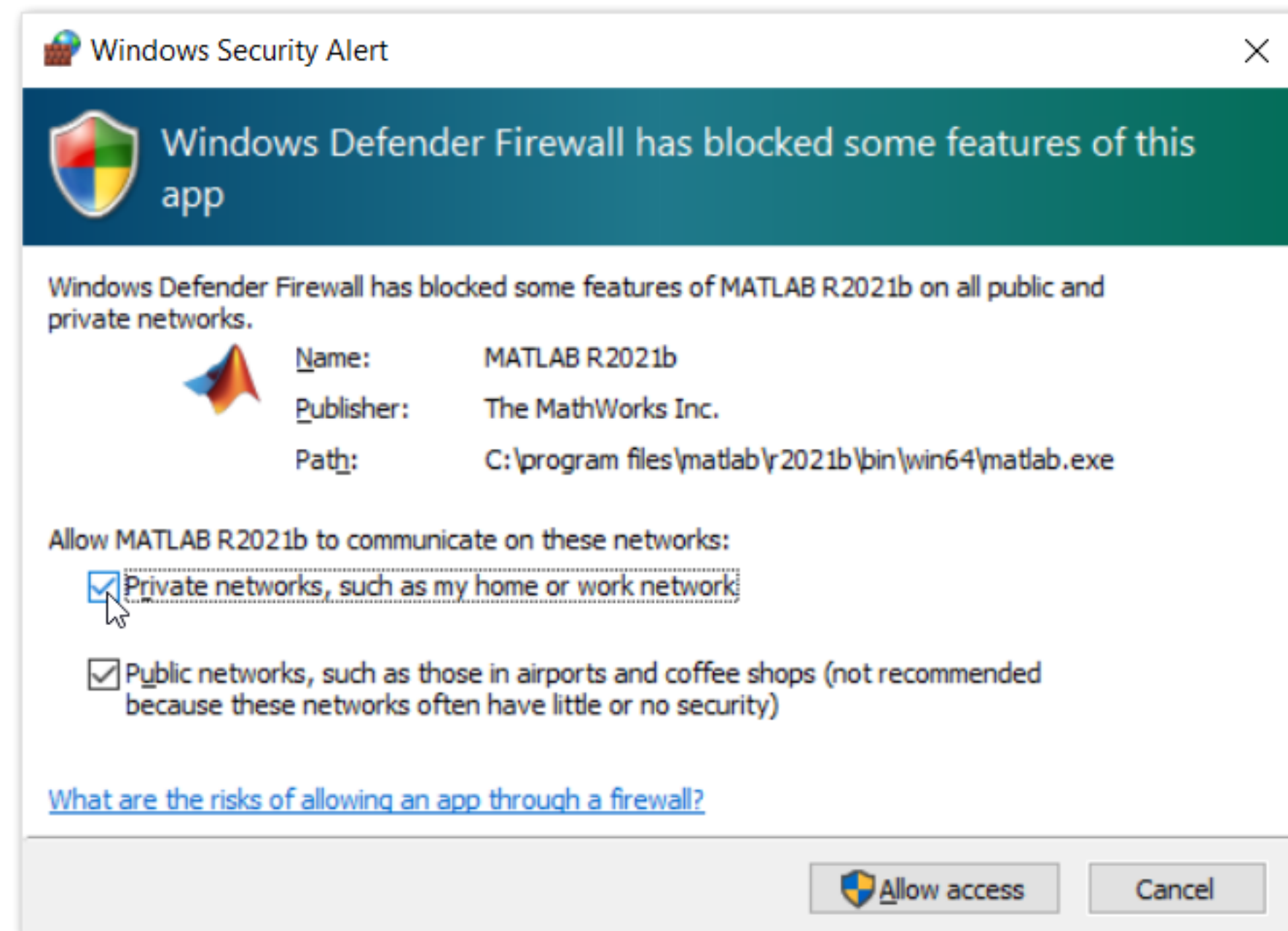
Per-process Firewall

Most “personal” firewalls still allow all outgoing traffic by default

Severe usability problems otherwise

Do all programs really need to communicate with the outside world?

Deny by default and allowlist only what is needed



Routers: “Secure Gateways”

- **Nowadays it is common for most of the discussed technologies to be consolidated into a single box – Your router**

Routing, Firewall, NAT, VPN, Proxy, WiFi access point, ... Common in home and enterprise settings

- **Routers and firewalls used to be “simple” devices – not anymore**

Features —> complexity —> security issues

- **Routers themselves have become critical hosts in the network that need to be protected**

Administrative interface, OS patches/updates, service vulnerabilities, ...

RouterPasswords.com

Welcome to the internet's largest and most updated default router passwords database,

Select Router Manufacturer:

CISCO

Find Password

Manufacturer	Model	Protocol	Username	Password
CISCO	CACHE ENGINE	CONSOLE	admin	diamond
CISCO	CONFIGMAKER		cmaker	cmaker
CISCO	CNR Rev. ALL	CNR GUI	admin	changeme
CISCO	NETRANGER/SECURE IDS	MULTI	netrangr	attack
CISCO	BBSM Rev. 5.0 AND 5.1	TELNET OR NAMED PIPES	bbsd-client	changeme2
CISCO	BBSD MSDE CLIENT Rev. 5.0 AND 5.1	TELNET OR NAMED PIPES	bbsd-client	NULL

VPNFilter malware infecting 500,000 devices is worse than we thought

Malware tied to Russia can attack connected computers and downgrade HTTPS.

DAN GOODIN - 6/6/2018, 9:00 AM

157



Two weeks ago, officials in the private and public sectors warned that hackers working for the Russian government infected more than 500,000 consumer-grade routers in 54 countries with malware that could be used for a range of nefarious purposes. Now, researchers from Cisco's Talos security team say additional analysis shows that the malware is more powerful than originally thought and runs on a much broader base of models, many from previously unaffected manufacturers.

The most notable new capabilities found in VPNFilter, as the malware is known, come in a newly discovered module that performs an active man-in-the-middle attack on incoming Web traffic.

Attackers can use this ssler module to inject malicious payloads into traffic as it passes through an infected router. The payloads can be tailored to exploit specific devices connected to the infected network. Pronounced "essler," the module can also be used to surreptitiously modify content delivered by websites.



FURTHER READING

Hackers infect 500,000 consumer routers all over the world with malware



IOT SECURITY

Researchers Discover 40,000-Strong EOL Router, IoT Botnet

Malware hunters sound an alarm after discovering a 40,000-strong botnet packed with end-of-life routers and IoT devices being used in cybercriminal activities.



By [Ryan Naraine](#)
March 26, 2024



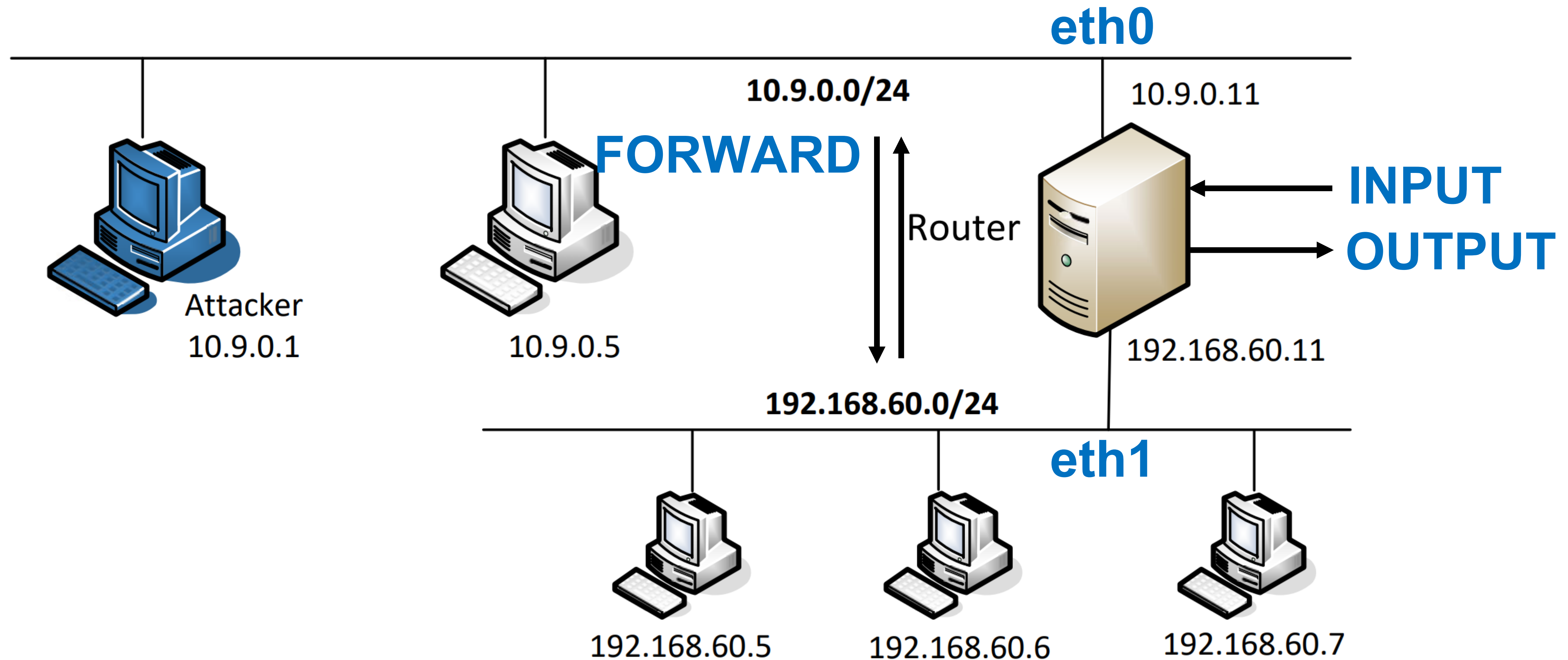
Malware hunters at Lumen Technologies on Tuesday sounded an alarm after discovering a 40,000-strong botnet packed with end-of-life routers and IoT devices being used in cybercriminal activities.

According to new documentation from Lumen's Black Lotus Labs, a notorious cybercriminal group has been running a multi-year campaign targeting end-of-life

TRENDING

- 1 Supply Chain Attack: Major Linux Distributions Impacted by XZ Utils Backdoor
- 2 XZ Utils Backdoor Attack Brings Another Similar Incident to Light

Example: Router Firewall (Homework 4)



Example: Router Firewall

Implement a router firewall with the following restrictions:

1. Outside hosts can ping the router and receive response.
2. Internal hosts can ping outside hosts and receive response.
3. All other packets from external networks to the router should be blocked.
4. All other packets between the internal and external networks should be blocked.

Least Privilege Principle:

Grant the least amount of rights/privilege to satisfy the requirements.

1. Outside hosts can ping the router and receive response.
2. Internal hosts can ping outside hosts and receive response.
3. All other packets from external networks to the router should be blocked.
4. All other packets between the internal and external networks should be blocked.

Goal	Chain	Source Interface	Destination Interface	Protocol	Message Type (ICMP)	Action
1	INPUT	eth0 (Ext)	N/A	ICMP	Echo-request (Type 8)	ACCEPT
2 (Request)	FORWARD	eth1 (Int)	eth0 (Ext)	ICMP	Echo-request (Type 8)	ACCEPT
2 (Reply)	FORWARD	eth0 (Ext)	eth1 (Int)	ICMP	Echo-reply (Type 0)	ACCEPT
3	INPUT	Any	N/A	Any	Any	DROP
4	FORWARD	Any	Any	Any	Any	DROP
1, 3	OUTPUT	N/A	Any	Any	Any	ACCEPT

Example: Router Firewall

- Outside hosts can ping the router and receive response.

```
iptables -A INPUT -i eth0 -p icmp --icmp-type echo-request -j ACCEPT
```

- Internal hosts can ping outside hosts and receive response.

```
iptables -A FORWARD -i eth1 -o eth0 -p icmp --icmp-type echo-request -j ACCEPT
```

```
iptables -A FORWARD -i eth0 -o eth1 -p icmp --icmp-type echo-reply -j ACCEPT
```

- All other packets from external networks to the router should be blocked.

```
iptables -P INPUT DROP
```

```
iptables -P OUTPUT ACCEPT
```

- All other packets between the internal and external networks should be blocked.

```
iptables -P FORWARD DROP
```

Beyond Firewalls

- **The “safe” network perimeter approach does not apply to modern environments and threats**

Internal devices may will be compromised: phishing, insiders, Bring your own device (BYOD), work from home/anywhere, ...

Establishing trusted vs. untrusted network boundaries enforced through firewalls becomes pointless: what happens when the perimeter is breached?

- **Alternative: consider the “internal” network as untrusted too!**

Shift access control from the network perimeter to individual users

- **Popularized by Google: *BeyondCorp***

An implementation of a “zero trust” architecture



NSA infiltrates links to Yahoo, Google data centers worldwide, Snowden documents say

By [Barton Gellman](#) and Ashkan Soltani

October 30, 2013 at 5:50 p.m. EDT

The National Security Agency has secretly broken into the main communications links that connect Yahoo and Google data centers around the world, according to documents obtained from former NSA contractor [Edward Snowden](#) and interviews with knowledgeable officials.

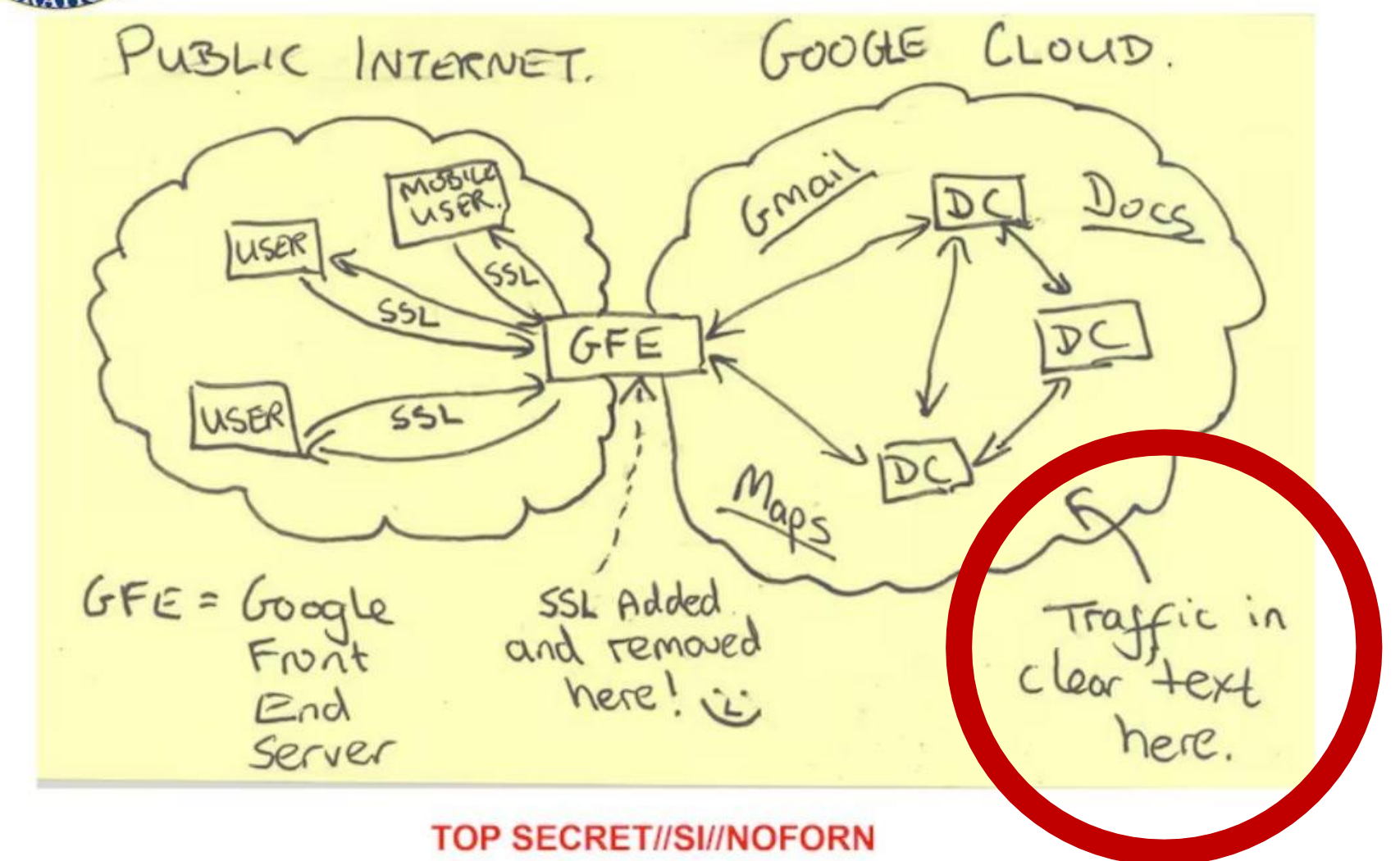
By tapping those links, the agency has positioned itself to collect at will from hundreds of millions of user accounts, many of them belonging to Americans. The NSA does not keep everything it collects, but it keeps a lot.

According to a top-secret accounting dated Jan. 9, 2013, the NSA's acquisitions directorate sends millions of records every day from

TOP SECRET//SI//NOFORN



Current Efforts - Google



TOP SECRET//SI//NOFORN

In this slide from a National Security Agency presentation on "Google Cloud Exploitation," a sketch shows where the "Public Internet" meets the internal "Google Cloud" where user data resides. Two engineers with close ties to Google exploded in profanity when they saw the drawing.

Zero Trust

Assume the network is always hostile and all devices and users are potentially compromised

Not a technology, but a strategy: “never trust, always verify”

Core principles

- **Identity:** users and devices must undergo continuous authentication and authorization before being granted access
- **Devices:** all devices (managed and unmanaged) should be continuously monitored and validated before access is granted; detailed inventory
- **Networks:** all traffic should be encrypted
- **Applications and workloads:** ensure secure application delivery; treat all applications and workloads as internet-connected
- **Data:** develop data categories and security policies to protect sensitive data